WM279-18 Information Risk and Security Management

Report on managing risk

5655691

IIoT Benefits:

Recent articles highlighted the Industrial Internet of Things (IIoT) as the key factor in transforming warehouses from traditional holding facilities into dynamic and intelligent "fulfillment factories", enhancing efficiency, accuracy and scalability through the addition of automation and robotics [1]. Notably in inventory management, this enables models to shift from reactive to predictive, utilising sensors for condition-based monitoring and just-in-time spare parts replenishment, significantly reducing cost and waste [3]. IIoT allows the facilitation of safety and human-focused innovation, providing systems capable of real-time occupational safety monitoring and creating a data-driven proactive/preventative safety environment. This is identified in cold storage warehouse research using BLE tags and digital twin technology for abnormal stationary detection, enabling spatial-temporal traceability and visibility. Unsupervised learning models analyse sensor data streams to identify danger patterns and deviations, directly addressing the fatal accident that initially motivated the research [2].

Cybersecurity Challenges:

In contrast, the literature consistently mentions the expanded attack surface, where every added device, like sensors, cameras or gateways, become potential entry points for attackers [1,2]. These risks are worsened by the rise of insecure, low-cost IIoT devices that prioritise functionality over security by having weak default passwords and a lack of security update functions [1,2]. Beyond access, using IIoT is threatened by data integrity and manipulation risks through spoofing sensor data like RSSI signals that may not only disrupt logistics [3] but also severely impact safety systems with false alarms or concealing real incidents [2]. Furthermore, the complexity of integrating new technology with legacy OT systems not designed for connectivity, creates insecure interfaces and persistent vulnerabilities, an identified issue of "integration of new technology with existing ones" [1,3].

Critical Analysis:

There is a distinct conflict in the usage of IIoT in warehouses, shown throughout the literature. Interconnectivity provides traceability, visibility, and real-time monitoring, but simultaneously creates an "exposition to cyber attacks" through expansions of the attack surface [3].

The issues stem from a governance gap, where cost and scalability is often prioritised over security, seen in the use of low-cost, low-energy consumption BLE devices [2]. This combination shows the complexity of IIoT in warehouses, demonstrating they are not a mere technology upgrade, but cyber-physical systems, where software and data directly control warehouse processes. For example, Automated Guided Vehicles (AGVs), sensors and cameras, and digital breaches, all directly influence physical operational failure, safety hazards and preventative measures [1]. Consequently, a compromise in IIoT infrastructure from risk management failures could lead to significant legal and regulatory liabilities, such as a breach of standards, notably: BS EN ISO 3691-4 [4] or Health and Safety in Work Act [5].

This suggests cyber-physical risks, so risk management must take a combination of digital and physical into consideration, especially in large scale facilities of 150,000 sqm, where technological infrastructure is designed to work alongside humans. The need for individual, device-focused risk analysis conducted throughout this report is confirmed,

providing practical security suggestions, specifically tailored to the audited warehouse’s IIoT ecosystem.

Risk assessment:

Define the Scope:

The scope of this risk assessment, following the ISO 27005 framework [14], covers the IIoT infrastructure of one of the largest warehouses in the UK. Handling vast amounts of e-commerce orders across multiple sections, the 150,000 sqm automated warehouse is supported by seven key assets.

The risk appetite is defined as Zero for safety incidents, reflecting standards such as BS EN ISO 3691-4 [4] and the Health and Safety at Work Act 1974 [5]. Since staff work alongside automated systems, toleration for operational disruption and cyber risks impacting safety sensors is low. Minor disruptions are allowed if the organisation considers the costs of mitigation to be higher than financial loss caused. Stakeholders include workers, who depend on sensors functioning properly, IT management who maintain the IIoT network, and customers, who rely on fulfillment.

Asset Identification:

Asset ID	Device name	Asset owner	Asset type	Description
A1	Axis P1468-LE	Safety	Hardware	Human and vehicle detection
A2	Tuya Smart Camera U6N	Security	Hardware	Warehouse surveillance
A3	EcoStruxure Link150	IT	Network	Network connector
A4	Honeywell HVAC T6 Pro	Facility	Hardware	Climate control
A5	Zebra FX9600[15]	Logistics	Hardware	Inventory tracking
A6	MOCREO Smart Passive Infrared (PIR) Sensors	Security/safety	Hardware	Motion detection
A7	Foscam F18620 IP	Security	Hardware	Warehouse surveillance

Threats and Vulnerabilities Identification:

Asset ID	Threat	Vulnerability	Impact	Impact Score	Justification
A1	RCE: Hijacking system	CVE-2022-23410: DLL	Risk of fatal human-vehicle	5	Significant safety risk

		hijacking	collision		
A2	DoS: Video tampering	CVE-2024-32268: Allows Denial of Service	Undetected entry	2	Other security measures
A3	Lateral Movement: Access to devices	Modbus TCP vulnerability: Allows access into network	Access to all IIoT devices	4	Affects devices on network
A4	Sabotage: Changing temperature	WPA2 Weakness: Weak encryption	Spoilage of goods	2	Limited to temperature-dependent products
A5	Data tampering: Spoofing inventory levels	CVE-2021-32089: Unauthenticated file uploads and code execution	Inaccurate data affects operations	4	Prevents replenishment and fulfillment
A6	Signal jamming: Disables Infrared triggers	Unencrypted RF: Vulnerable frequency	Undetected entry	2	Other security measures
A7	Botnet recruitment: Device used in DDoS	Legacy system: No security patches due to End-of-Life	Lower performance of devices on network	2	Affects performance instead of safety

Risk Register and Prioritisation Analysis:

Asset ID	Threat	Likelihood	Impact	Risk score (L x I)	Priority
A1	RCE	3	5	15	2
A2	DoS	3	3	6	5/6
A3	Lateral movement	4	4	16	1
A4	Sabotage	3	2	6	5/6
A5	Data tampering	3	4	12	3
A6	Signal jamming	2	2	4	7
A7	Botnet recruitment	5	2	10	4

This register evaluates the 7 devices, prioritising safety risk:

Likelihood: 1 - Extremely Rare Occurrence, 5 - Almost Certain

Impact: 1 - Negligible Impact to Operations (short operations delay), 5 - Catastrophic (fatal human injury/total warehouse shutdown)

Risk score: Identifies risk severity and management prioritisation

Critical Evaluation of 2 Severe Risks:

Following the Risk Register analysis, a critical evaluation of the two most severe risks identified with highest priority has been conducted: The Axis P1468-LE Camera and the EcoStruxure Link150 Gateway. These devices are identified as the greatest threats to the 150,000 sqm warehouse, due to their respective roles as a safety sensor and a single point of failure. These risks will be evaluated from a cyber-physical perspective, analysing technical attack vectors, operational and security consequences, and legal implications under UK standards.

The **Axis P1468-LE Camera** surpasses traditional surveillance, using advanced analytics based on deep learning. Based on the ARTPEC-8 chipset, the camera features a deep learning processing unit (DLPU), and combined with Axis Object Analysis, which detects and classifies humans and vehicles [6], it functions as a “perception system” for industrial automation, preventing collisions between humans and automated guided vehicles in high-traffic zones.

Notable vulnerabilities include CVE-2022-23410 (CVSS 7.8) [7], and more recently the critical CVE-2025-30023 (CVSS 9.0) [8], Remote Code Execution (RCE) flaws. Despite featuring “secure boot” [6] protections, the camera remains susceptible to RCE, allowing attackers to bypass these security measures during runtime. Furthermore, MQTT protocols for communication with other IIoT devices and Industrial Control Systems bridges the security and operational networks, presenting itself as a high target for lateral movement. The attacker achieves greater value from device exploitation: viewing and disabling video functions, and also accessing the broader operational environment.

The cyber-physical consequences are false negatives, caused by an attacker tampering with the system, feeding spoofed signals to the analytics engine, or modifying MQTT messages. An analytics engine compromise may result in the failure of detecting human workers to relay to AGVs, presenting a direct risk of a collision that may result in a fatal accident.

This suggests a governance gap, a failure to update the AXIS OS leaving the camera susceptible to public exploits, with recurring RCE vulnerabilities, potentially violating the UK Health and Safety at Work Act 1974 [5]. Furthermore, these breach BS EN ISO 3691-4 [4], since the camera acts as a safety feature of the AGVs control system, and attacks such as signal spoofing that lead to the “false negative” detection is a direct risk of fatal collision. Although not a safety or operational regulation, a breach of the “Live Privacy Shield” [6] risks GDPR [9] violations through unauthorised worker surveillance. The safety role of the Axis P1468-LE prioritises security in order to maintain operational continuity and legal compliance.

The **EcoStruxure Link150 Gateway** is a core component of digital infrastructure, bridging the IT network to the Operational Technology (OT) network, translating Modbus TCP from certain devices for warehouse management. It is important for connectivity between devices and the main system, so it creates a Single Point of Failure in which a breach can affect several devices across the network, making it a desirable target due to lateral movement potential. The most significant vulnerability is identified as the weakness in Modbus TCP protocol, combined with CVE-2021-22779 (CVSS 8.1), allowing for authentication bypass by spoofing, leading to unauthorised access in read and write mode [10].

An exploitation of this vulnerability allows for navigation from a compromised device through the Link150 gateway and into the OT network, accessing all IIoT devices. The cyber-physical consequences involve multi-vector attacks, since attackers can simultaneously disable systems across the network, causing widespread failures across the warehouse, potentially being disruptive enough to create a warehouse shutdown where systems are uncontrollable or dysfunctional. This would lead to financial losses due to lack of fulfillment, and risk to humans or infrastructure.

The Link150 gateway violates the ISO 27001 standard [11] by relying on unencrypted legacy protocols suggesting a lack of “Security by Design” [12] and failure to separate IT and OT networks. Additionally, due to the nature of the environment and the fact that the gateway is a core system connecting all the devices together, secondary impacts would be failures in other devices such as the Axis P1468-LE camera, potentially resulting in a fatal accident. This could then be interpreted as a breach of the UK Health and Safety Act 1974 [5], creating an unsafe work environment.

Risk Treatment Plan:

Risk Treatment Options and Mitigation Strategies:

Asset ID	Risk Score	Treatment option	Treatment Measures	Priority
A3	16	Reduce	Installation of deep packet inspection firewall	High
A1	15	Reduce	Installing patched version of AXIS IP Utility (v4.18.0+)	High
A5	12	Avoid	Replace unsupported devices with newer, supported models	Medium
A7	10	Avoid	Replace legacy devices with newer alternatives	Medium
A2	6	Reduce	Place devices on a dedicated VLAN to isolate from network	Low
A4	6	Reduce	Regularly update for most recent security patches	Low

Specific Risk Treatment Options and Mitigation Strategies:

Recommendation 1: Deep Packet Inspection Firewall

The Link150 Gateway has been identified as a Single Point of Failure, due to the connectivity and the weakness in unencrypted Modbus TCP protocols. As the protocol is unable to be patched, an alternative treatment would be to implement a firewall with Deep Packet Inspection (DPI) in order to create a protective layer for communication. The highlighted exploit CVE-2021-22779 could potentially cause unauthorised access in read and write mode to the controller by spoofing Modbus communication [10], and by inspecting the content of packets, unauthorised commands that may affect other IIoT devices on the network would be blocked. This prevents lateral movement as other devices are unaffected, significantly limiting the impact and evaluated risks, reducing the risk score from 16 to 8, as it does not completely eliminate the consequences of a breach.

Recommendation 2: Security patching and network segmentation

The Axis P1468-LE camera is the most significant human-safety device, acting as the detection system for the AGVs in the warehouse. Addressing common vulnerabilities such as CVE-2022-23410 [7] and CVE-2025-30023 [8] are easily remedied, requiring a firmware update with security patching in order to close the attack vector. However, this requires waiting for Axis Communications to create and release the update, in which time the vulnerability may be exploited. Therefore, a secondary recommendation for the camera is to separate these devices from the main network, adding them to their own dedicated VLAN, hindering attackers that access the network through methods such as exploiting the gateway from being able to modify the data feeds that the cameras rely on. This would prevent the breach of BS EN ISO 3691-4 [4], protecting safety control systems from unauthorised interference, significantly lowering the likelihood and reducing risk score from 15 to 5, positioning itself with the zero safety tolerance.

Recommendation 3: Decommission and replacement of devices

The Zebra FX9500 Fixed RFID Readers are the main devices that analyse inventory levels in order to automate replenishment and fulfillment of products in the warehouse. Spoofing of the data may incorrectly display stock, preventing proper fulfillment which in turn results in financial loss. The identified CVE-2021-32089 [13] was solved by updating firmware with new security patches, and since we have assumed the use of the old, unsupported model, the recommendation would be to replace them. This would reduce the likelihood so that the risk score drops from 12 to 8, due to the fact that security patches are not immediate.

APPENDIX:

[1] Rodríguez-García, M. *et al.* (2025) 'Managing technology-related disruptions and vulnerabilities in highly automated warehouse systems: an integrative review and research agenda', *International Journal of Production Research*, pp. 1–33. doi: 10.1080/00207543.2025.2552281

[2] Zhan, X., Wu, W., Shen, L., Liao, W., Zhao, Z. and Xia, J. (2022). Industrial internet of things and unsupervised deep learning enabled real-time occupational safety monitoring in cold storage warehouse. *Safety Science*, 152, p.105766. doi:https://doi.org/10.1016/j.ssci.2022.105766.

[3] Khan, N., Wei Deng Solvang and Yu, H. (2024). Industrial Internet of Things (IIoT) and Other Industry 4.0 Technologies in Spare Parts Warehousing in the Oil and Gas Industry: A Systematic Literature Review. *Logistics*, 8(1), pp.16–16. doi:https://doi.org/10.3390/logistics8010016.

[4] 14:00-17:00 (n.d.). *ISO 3691-4:2023*. [online] ISO. Available at: https://www.iso.org/standard/83545.html.

[5] GOV.UK (1974). *Health and Safety at Work etc. Act 1974*. [online] legislation.gov.uk. Available at: https://www.legislation.gov.uk/ukpga/1974/37/contents.

[6] Axis.com. (2025). *AXIS P1468-LE Bullet Camera | Axis Communications*. [online] Available at: https://www.axis.com/products/axis-p1468-le.

[7] Axis Communications (2022) *Security advisory: CVE-2022-23410*. Available at: https://www.axis.com/dam/public/a0/7d/48/cve-2022-23410-en-US-359858.pdf.

[8] Axis Communications (2025) *Critical security vulnerability in AXIS OS: CVE-2025-30023*. Available at: https://www.axis.com/dam/public/9b/a5/72/cve-2025-30023pdf-en-US-485733.pdf.

[9] GDPR (2018). *General Data Protection Regulation (GDPR)*. [online] General Data Protection Regulation (GDPR). Available at: https://gdpr-info.eu.

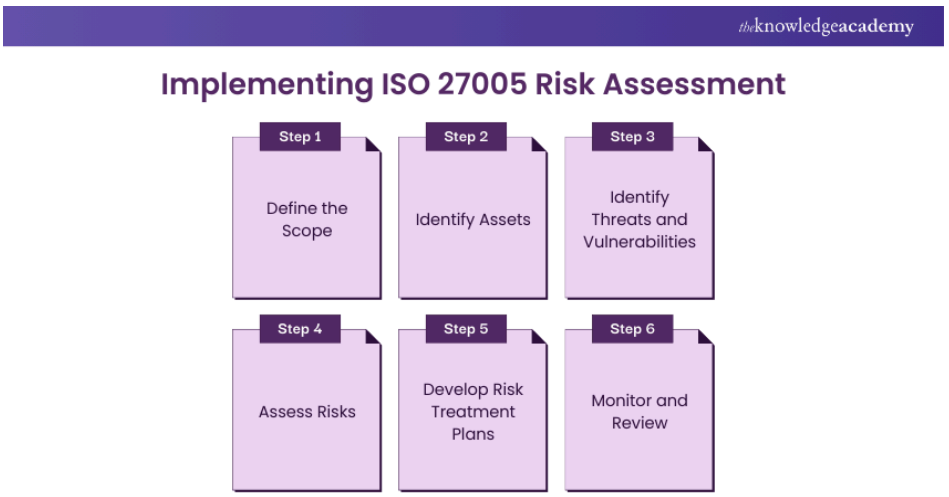
[10] Nist.gov. (2021). *NVD - CVE-2021-22779*. [online] Available at: https://nvd.nist.gov/vuln/detail/CVE-2021-22779.

[11] International Organization for Standardization (2022). *ISO/IEC 27001 standard – information security management systems*. [online] ISO. Available at: https://www.iso.org/standard/27001.

[12] ISMS.online. (2022). *How to Implement ISO 27001 Annex A 8.27 Secure System Architecture*. [online] Available at: https://www.isms.online/iso-27001/annex-a-2022/how-to-implement-iso-27001-2022-annex-a-control-8-27-secure-system-architecture-and-engineering-principles/.

[13] Cvedetails.com. (2021). *CVE-2021-32089 : An issue was discovered on Zebra (formerly Motorola Solutions) Fixed RFID Reader*. [online] Available at: https://www.cvedetails.com/cve/CVE-2021-32089/.

[14] The Knowledge Academy: ISO 27005 Risk Assessment Table



[15] Assumption: the zebra camera is an old, unsupported model